

Praneesh R V
CB.SC.U4CYS23036

Web Application Security Lab

Exercise 14

dashboard.php

Welcome, admin

[Logout](#)

```
<?php
session_start();

// If the user is not logged in, send them back to the login
page
if(!isset($_SESSION["username"]))
{
    header("Location: login.php");
    exit();
}
?>

<!DOCTYPE html>
<html>
<head>
    <title>Dashboard</title>
</head>
<body>
```

```
<h2>Welcome, <?php echo $_SESSION["username"]; ?></h2>

<a href="logout.php">Logout</a>

</body>
</html>
```

Login.php

Login Form

Invalid username or password

Username:

Password:

Login

```
<?php

session_start();

if(isset($_POST["login"]))
{
    $username = $_POST["username"];
    $password = $_POST["password"];

    // Simple hardcoded login check for learning purposes
    if($username === "admin" && $password === "1234")
    {
```

```
        $_SESSION["username"] = $username;
        header("Location: dashboard.php");
        exit();
    }
    else
    {
        $error = "Invalid username or password";
    }
}
?>

<!DOCTYPE html>
<html>
<head>
    <title>Login</title>
</head>
<body>

<h2>Login Form</h2>

<?php
if(isset($error))
{
    echo "<p style='color:red;'>$error</p>";
}
?>

<form method="post">
    Username:
    <input type="text" name="username">
    <br><br>

    Password:
    <input type="password" name="password">
```

```
<br><br>

    <input type="submit" name="login" value="Login">
</form>

</body>
</html>
```

Logout.php

```
<?php
session_start();

// Remove all session variables
session_unset();

// Destroy the session completely
session_destroy();

header("Location: login.php");
exit();
?>
```

Exercise 15

Create_table.sql

```
CREATE DATABASE php_lab;

USE php_lab;

CREATE TABLE students (
    id INT AUTO_INCREMENT PRIMARY KEY,
```

```
name VARCHAR(100) NOT NULL,  
email VARCHAR(100) NOT NULL,  
age INT NOT NULL  
);
```

dbconnect.php

<?php

```
// Connect to MySQL server  
$conn = mysqli_connect("localhost", "root", "", "php_lab");  
  
// Check whether the connection was successful  
if(!$conn)  
{  
    die("Connection failed: " . mysqli_connect_error());  
}  
  
echo "Connected to MySQL successfully";  
  
?>
```

Exercise 16

Insert_student.php

<?php

```
$conn = mysqli_connect("localhost", "root", "", "php_lab");
```

```

if (!$conn)
{
    die("Connection failed: " . mysqli_connect_error());
}

if ($_SERVER["REQUEST_METHOD"] == "POST")
{
    $name = trim($_POST["name"]);
    $email = trim($_POST["email"]);
    $age = (int)$_POST["age"];

    // Prepared statement helps safely insert data into the
    database
    $stmt = mysqli_prepare($conn, "INSERT INTO students (name,
email, age) VALUES (?, ?, ?)");
    mysqli_stmt_bind_param($stmt, "ssi", $name, $email, $age);
    mysqli_stmt_execute($stmt);

    echo "<p style='color:green;'>Student record inserted
successfully.</p>";

    mysqli_stmt_close($stmt);
}

// Fetch all student records from the database
$result = mysqli_query($conn, "SELECT * FROM students");
?>

<!DOCTYPE html>
<html>
<head>
    <title>Student Records</title>
</head>

```

```
<body>

<h2>Insert Student Record</h2>

<form method="post">
    Name:
    <input type="text" name="name">
    <br><br>

    Email:
    <input type="email" name="email">
    <br><br>

    Age:
    <input type="number" name="age">
    <br><br>

    <input type="submit" value="Save">
</form>

<h2>Student List</h2>

<table border="1" cellpadding="8">
    <tr>
        <th>ID</th>
        <th>Name</th>
        <th>Email</th>
        <th>Age</th>
    </tr>

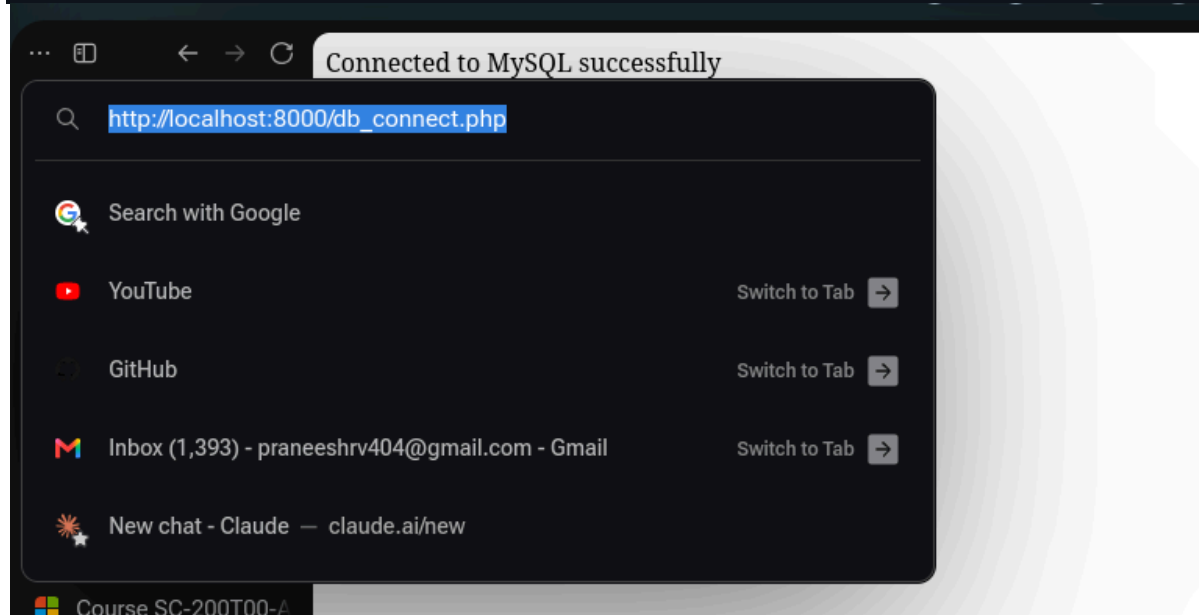
    <?php
    while($row = mysqli_fetch_assoc($result))
    {
        echo "<tr>";
```

```

        echo "<td>".$row["id"]."</td>";
        echo "<td>".$row["name"]."</td>";
        echo "<td>".$row["email"]."</td>";
        echo "<td>".$row["age"]."</td>";
        echo "</tr>";
    }
    ?>
</table>

</body>
</html>

```



Exercise 16

```
<?php
```

```

$conn = mysqli_connect("localhost", "root", "yourpassword",
"php_lab");
if (!$conn)
{
    die("Connection failed: " . mysqli_connect_error());
}

```



```
if($_SERVER["REQUEST_METHOD"] == "POST")
{
    $name = trim($_POST["name"]);
    $email = trim($_POST["email"]);
    $age = (int)$_POST["age"];

    // Prepared statement helps safely insert data into the
    database
    $stmt = mysqli_prepare($conn, "INSERT INTO students (name,
    email, age) VALUES (?, ?, ?)");
    mysqli_stmt_bind_param($stmt, "ssi", $name, $email, $age);
    mysqli_stmt_execute($stmt);

    echo "<p style='color:green;'>Student record inserted
    successfully.</p>";

    mysqli_stmt_close($stmt);
}

// Fetch all student records from the database
$result = mysqli_query($conn, "SELECT * FROM students");
?>

<!DOCTYPE html>
<html>
<head>
    <title>Student Records</title>
</head>
<body>

<h2>Insert Student Record</h2>

<form method="post">
    Name:
```

```
<input type="text" name="name">
<br><br>

Email:
<input type="email" name="email">
<br><br>

Age:
<input type="number" name="age">
<br><br>

<input type="submit" value="Save">
</form>

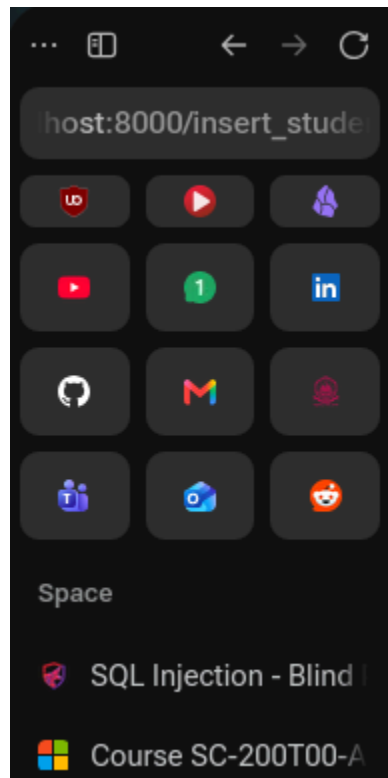
<h2>Student List</h2>

<table border="1" cellpadding="8">
  <tr>
    <th>ID</th>
    <th>Name</th>
    <th>Email</th>
    <th>Age</th>
  </tr>

  <?php
  while($row = mysqli_fetch_assoc($result))
  {
    echo "<tr>";
    echo "<td>".$row["id"]."</td>";
    echo "<td>".$row["name"]."</td>";
    echo "<td>".$row["email"]."</td>";
    echo "<td>".$row["age"]."</td>";
    echo "</tr>";
  }
```

```
?>
</table>

</body>
</html>
```



Insert Student Record

Name:

Email:

Age:

Student List

ID	Name	Email	Age
----	------	-------	-----

Student record inserted successfully.

Insert Student Record

Name:

Email:

Age:

Save

Student List

ID	Name	Email	Age
1	praneesh	praneeshrv404@gmail.com	21

Mini Challenge

```
<?php
function calculateTotal(array $marks): int {
    $total = 0;
    foreach ($marks as $mark) {
        $total += $mark;
    }
    return $total;
}
function calculateAverage(array $marks): float {
    $total = calculateTotal($marks);
    return $total / count($marks);
}
```

```
function findHighest(array $marks): int {
    return max($marks);
}

function findLowest(array $marks): int {
    return min($marks);
}

function assignGrade(float $average): string {
    if ($average >= 90) {
        return 'A';
    } elseif ($average >= 80) {
        return 'B';
    } elseif ($average >= 70) {
        return 'C';
    } elseif ($average >= 60) {
        return 'D';
    } else {
        return 'F';
    }
}

function resultStatus(array $marks): string {
    foreach ($marks as $mark) {
        if ($mark < 35) {
            return 'Fail';
        }
    }
    return 'Pass';
}

$submitted = false;
```

```
$studentName = '';
$marks       = [];
$total       = 0;
$average     = 0;
$grade       = '';
$status      = '';
$highest     = 0;
$lowest      = 0;
$error       = '';

if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    $studentName = trim($_POST['student_name'] ?? '');
    $mark1 = $_POST['mark1'] ?? '';
    $mark2 = $_POST['mark2'] ?? '';
    $mark3 = $_POST['mark3'] ?? '';

    if ($studentName === '' || $mark1 === '' || $mark2 === '' ||
$mark3 === '') {
        $error = 'Please fill in the student name and all three
marks.';
    } elseif (!is_numeric($mark1) || !is_numeric($mark2) ||
!is_numeric($mark3)) {
        $error = 'Marks must be numeric values.';
    } else {
        $marks = [(int)$mark1, (int)$mark2, (int)$mark3];

        $total    = calculateTotal($marks);
        $average  = calculateAverage($marks);
        $grade    = assignGrade($average);
        $status   = resultStatus($marks);
        $highest  = findHighest($marks);
        $lowest   = findLowest($marks);

        $submitted = true;
    }
}
```

```

    }
}
?>
<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="UTF-8">
<title>Student Grade Calculator</title>
<style>
    body { font-family: Arial, sans-serif; background: #f4f6f8;
margin: 0; padding: 40px 20px; }
    .card { max-width: 480px; margin: 0 auto; background: #fff;
border-radius: 8px;
        padding: 30px; box-shadow: 0 2px 8px rgba(0,0,0,0.1);
    }
    h1 { font-size: 22px; margin-top: 0; color: #2c3e50; }
    label { display: block; margin-top: 14px; font-weight: bold;
color: #34495e; font-size: 14px; }
    input[type=text], input[type=number] {
        width: 100%; padding: 8px; margin-top: 4px; box-sizing:
border-box;
        border: 1px solid #ccc; border-radius: 4px; font-size:
14px;
    }
    button {
        margin-top: 20px; width: 100%; padding: 10px; background:
#2980b9; color: #fff;
        border: none; border-radius: 4px; font-size: 15px;
cursor: pointer;
    }
    button:hover { background: #1f6690; }
    .error { color: #c0392b; margin-top: 12px; font-size: 14px; }
    .result { margin-top: 25px; padding: 18px; background:
#ecf6ff; border-left: 4px solid #2980b9;

```

```

        border-radius: 4px; font-size: 15px; line-height:
1.8; }
    .result strong { color: #2c3e50; }
    .pass { color: #27ae60; font-weight: bold; }
    .fail { color: #c0392b; font-weight: bold; }
</style>
</head>
<body>
<div class="card">
    <h1>Student Grade Calculator</h1>

    <form method="POST" action="">
        <label for="student_name">Student Name</label>
        <input type="text" id="student_name" name="student_name"
            value="<?= htmlspecialchars($studentName) ?>"
required>

        <label for="mark1">Mark 1 (Subject 1)</label>
        <input type="number" id="mark1" name="mark1" min="0"
max="100"
            value="<?= htmlspecialchars($_POST['mark1']) ?? ''"
?>" required>

        <label for="mark2">Mark 2 (Subject 2)</label>
        <input type="number" id="mark2" name="mark2" min="0"
max="100"
            value="<?= htmlspecialchars($_POST['mark2']) ?? ''"
?>" required>

        <label for="mark3">Mark 3 (Subject 3)</label>
        <input type="number" id="mark3" name="mark3" min="0"
max="100"
            value="<?= htmlspecialchars($_POST['mark3']) ?? ''"
?>" required>

```



```
<button type="submit">Calculate Grade</button>
</form>

<?php if ($error): ?>
    <div class="error"><?= htmlspecialchars($error) ?></div>
<?php endif; ?>

<?php if ($submitted): ?>
    <div class="result">
        <strong>Student Name</strong> : <?=
htmlspecialchars($studentName) ?><br>
        <strong>Marks</strong> : <?= implode(' ', $marks)
?><br>
        <strong>Total</strong> : <?= $total ?><br>
        <strong>Average</strong> : <?=
number_format($average, 2) ?><br>
        <strong>Grade</strong> : <?= $grade ?><br>
        <strong>Highest Mark</strong> : <?= $highest ?><br>
        <strong>Lowest Mark</strong> : <?= $lowest ?><br>
        <strong>Result</strong> :
        <span class="<?= $status === 'Pass' ? 'pass' : 'fail'
?>"><?= $status ?></span>
    </div>
<?php endif; ?>
</div>
</body>
</html>
```

Student Grade Calculator

Student Name

Mark 1 (Subject 1)

Mark 2 (Subject 2)

Mark 3 (Subject 3)

Calculate Grade

Student Name : dinesh

Marks : 100, 90, 97

Total : 287

Average : 95.67

Grade : A

Highest Mark : 100

Lowest Mark : 90

Result : **Pass**

Auth_check.php

```
<?php
if (session_status() !== PHP_SESSION_ACTIVE) {
    session_start();
}
```

```
}

if (!isset($_SESSION['username'])) {
    header('Location: loginform.php');
    exit();
}
```

Db.php

```
<?php

$host = 'localhost';
$dbname = 'grade_system';
$dbuser = 'grade_app';
$dbpass = 'GXfDCnkAuR70piN6lS43VId';

try {
    $pdo = new
PDO("mysql:host=$host;dbname=$dbname;charset=utf8mb4", $dbuser,
$dbpass, [
        PDO::ATTR_ERRMODE => PDO::ERRMODE_EXCEPTION,
        PDO::ATTR_DEFAULT_FETCH_MODE => PDO::FETCH_ASSOC,
    ]);
} catch (PDOException $e) {
    die('Connection failed: ' . $e->getMessage());
}
```

Loginform.php

```
<?php

if (session_status() !== PHP_SESSION_ACTIVE) {
    session_start();
}
```

```

$username = $_COOKIE['username'] ?? '';
$error = $_GET['error'] ?? '';
?>
<!DOCTYPE html>
<html>
<head><title>Login</title></head>
<body>
<h2>Student Login</h2>

<?php if ($error): ?>
    <p style="color:red;"><?= htmlspecialchars($error) ?></p>
<?php endif; ?>

<form method="post" action="login.php">
    Username: <input type="text" name="username" value="<?=
htmlspecialchars($username) ?>"><br><br>
    Password: <input type="password" name="password"><br><br>
    <input type="submit" value="Login">
</form>

</body>
</html>

```

Login.php

```

<?php
if (session_status() !== PHP_SESSION_ACTIVE) {
    session_start();
}
require 'db.php';

if ($_SERVER['REQUEST_METHOD'] !== 'POST') {
    header('Location: loginform.php');
}

```

```

        exit();
    }

$username = trim($_POST['username'] ?? '');
$password = $_POST['password'] ?? '';

$stmt = $pdo->prepare('SELECT * FROM users WHERE username = ?');
$stmt->execute([$username]);
$user = $stmt->fetch();

if ($user && password_verify($password, $user['password'])) {
    $_SESSION['username'] = $user['username'];
    setcookie('username', $user['username'], time() + 7 * 24 * 60
* 60, '/');
    header('Location: welcome.php');
    exit();
}

header('Location: loginform.php?error=' . urlencode('Invalid
username or password'));
exit();

```

Logout.php

```

<?php
if (session_status() !== PHP_SESSION_ACTIVE) {
    session_start();
}

$_SESSION = [];

if (ini_get('session.use_cookies')) {
    $params = session_get_cookie_params();

```

```

        setcookie(session_name(), '', time() - 42000,
$params['path'], $params['domain'], $params['secure'],
$params['httponly']);
    }

    session_destroy();

    header('Location: loginform.php');
    exit();

```

welcome.php<?php

```

require 'auth_check.php';
?>
<!DOCTYPE html>
<html>
<head><title>Welcome</title></head>
<body>
<h2>Welcome, <?= htmlspecialchars($_SESSION['username'])
?>!</h2>
<p><a href="grade_calculator.php">Grade Calculator</a></p>
<p><a href="logout.php">Logout</a></p>
</body>
</html>

```

Setup.sql

```

CREATE DATABASE IF NOT EXISTS grade_system;

USE grade_system;

CREATE TABLE IF NOT EXISTS users (
    id INT AUTO_INCREMENT PRIMARY KEY,
    username VARCHAR(50) NOT NULL UNIQUE,
    password VARCHAR(255) NOT NULL
);

```

```
INSERT INTO users (username, password) VALUES ('123',
'$2y$12$3Q0YiFn/fnis/PWBbRI56u0OFZyEI2laTVXFMGW5HPSq677HklfYW');

CREATE USER IF NOT EXISTS 'grade_app'@'localhost' IDENTIFIED BY
'GXfDCnkAuR70piN6lS43VId';
GRANT SELECT, INSERT, UPDATE, DELETE ON grade_system.* TO
'grade_app'@'localhost';
FLUSH PRIVILEGES;
```